ROTEIRO DE ESTUDOS · SERVIDORES LINUX · MÓDULO 03

Usuários, grupos, permissões e sudo

Contas locais e arquivos de identidade, envelhecimento de senha, grupos, sudo, permissões ugo/rwx, umask, bits especiais, ACLs e PAM

Nível	Básico
Carga sugerida	1 semana (8–10 h)
Pré-requisitos	Módulo 02
Relação com RHCSA / LFCS	RHCSA: "Manage users and groups", permissões ugo/rwx, "Manage default file permissions", "Configure privileged access"; LFCS: Users and Groups (10%)

Objetivos do módulo

- Entender como o Linux identifica usuários e grupos (UID, GID) e onde isso fica gravado.
- Criar, alterar e remover usuários e grupos; definir senhas e envelhecimento.
- Conceder acesso administrativo com `sudo` de forma controlada.
- Ler e alterar permissões em notação simbólica e octal; definir a `umask`.
- Usar SUID, SGID e sticky bit, e saber por que eles importam para a segurança.
- Aplicar ACLs para permissões além do dono/grupo/outros.
- Entender o papel do PAM e como cada distribuição o gerencia.

1. Identidade no Linux

Arquivo	Conteúdo
`/etc/passwd`	Uma linha por conta: `nome:x:UID:GID:comentário:home:shell` (legível por todos; a senha não fica aqui)
`/etc/shadow`	Hash da senha e regras de envelhecimento (só root lê)
`/etc/group`	Grupos: `nome:x:GID:membros-secundários`
`/etc/gshadow`	Senhas e administradores de grupos
`/etc/login.defs`	Padrões: faixa de UIDs, envelhecimento, criação da home
`/etc/skel/`	Modelo copiado para a home de cada novo usuário

- **root** tem UID 0 e pode tudo. **Contas de sistema** (serviços) ficam abaixo de 1000 e normalmente têm shell `/sbin/nologin` ou `/usr/sbin/nologin`. **Usuários comuns** começam em 1000.
- Cada usuário tem um **grupo primário** (usado ao criar arquivos) e pode ter **grupos secundários**.

```
$ id; id ana
$ getent passwd ana          # consulta também fontes externas (LDAP, AD via SSSD)
$ getent group wheel sudo
$ who; w; last -n 10
```

2. Usuários

```
# useradd -m -c "Ana Souza" -s /bin/bash ana      # -m cria a home (no RHEL já é o padrão)
# passwd ana
# usermod -aG wheel ana                           # [RHEL] adiciona ao grupo administrativo
# usermod -aG sudo ana                            # [Ubuntu] idem
# usermod -L ana; usermod -U ana                  # bloqueia / desbloqueia a senha
# usermod -s /sbin/nologin svc-backup             # conta sem login interativo
# userdel -r antigo                               # remove usuário e home
```

ATENÇÃO

Em `usermod -aG`, o `-a` é essencial. Sem ele, `-G` **substitui** todos os grupos secundários do usuário, e você pode tirar alguém (ou você mesmo) do grupo administrativo.

NOTA

No Ubuntu existe também o `adduser`, um script interativo mais amigável que chama o `useradd` com os padrões da distribuição. Para scripts e para a prova, prefira `useradd`, que é igual nas duas famílias.

2.1 Envelhecimento de senha

```
# chage -l ana                    # mostra a política atual
# chage -M 90 -m 1 -W 7 ana       # máxima 90 dias, mínima 1, aviso 7 dias antes
# chage -d 0 ana                  # força troca no próximo login
# chage -E 2026-12-31 estagiario  # conta expira na data
```

Os padrões para contas novas ficam em `/etc/login.defs` (`PASS_MAX_DAYS`, `PASS_MIN_DAYS`, `PASS_WARN_AGE`). A complexidade das senhas é controlada pelo módulo **pam_pwquality** (`/etc/security/pwquality.conf`) e o bloqueio após falhas pelo **pam_faillock** (`/etc/security/faillock.conf`).

3. Grupos

```
# groupadd -g 2000 financeiro
# usermod -aG financeiro ana
# gpasswd -d ana financeiro        # remove ana do grupo
# groupmod -n fin financeiro       # renomeia
# groupdel fin
$ newgrp financeiro                # muda o grupo primário na sessão atual
```

4. Privilégios administrativos com sudo

Em servidores, não se trabalha logado como root. Usa-se uma conta pessoal e o **sudo**, que registra quem executou o quê.

	RHEL 10	Ubuntu 26.04
Grupo administrativo padrão	`wheel`	`sudo`
Implementação	sudo tradicional	**sudo-rs** (reimplementação em Rust); o original está disponível como `sudo.ws`
Root com senha	Opcional (definida no instalador)	Bloqueada por padrão; use `sudo`

Regras ficam em `/etc/sudoers` e, de preferência, em arquivos separados em `/etc/sudoers.d/`. **Edite sempre com** `visudo`, que valida a sintaxe antes de salvar; um erro de sintaxe pode impedir qualquer uso do sudo.

```
# visudo -f /etc/sudoers.d/operadores
# Grupo operadores pode reiniciar o nginx e ver logs, e nada mais
%operadores ALL=(root) /usr/bin/systemctl restart nginx, /usr/bin/journalctl -u nginx*

# Usuário deploy sem senha só para um script específico
deploy ALL=(root) NOPASSWD: /usr/local/sbin/publicar-site.sh
```

```
$ sudo -l                # o que eu posso executar?
$ sudo -i                # shell de root (use com moderação)
$ sudo -u postgres psql  # executar como outro usuário
```

SEGURANÇA

Liberar comandos que abrem shell ou editam arquivos arbitrários (`vi`, `less`, `find`, `tar`, `bash`, `python`) equivale a dar root completo, porque todos permitem escapar para um shell. Restrinja a comandos e argumentos específicos e revise os logs: as execuções do sudo aparecem no journal (`journalctl _COMM=sudo`).

5. Permissões básicas

```
$ ls -l /srv/financeiro
drwxrwx---. 2 root financeiro 4096 out 22 10:00 /srv/financeiro
-rw-r-----. 1 ana  financeiro  512 out 22 10:05 orcamento.ods
```

Posição	Significado
1º caractere	Tipo: `-` arquivo, `d` diretório, `l` link, `b`/`c` dispositivo
3 seguintes	Permissões do **dono** (u)
3 seguintes	Permissões do **grupo** (g)
3 últimos	Permissões dos **outros** (o)
`.` ou `+` no fim	`.` indica contexto SELinux; `+` indica que há ACL

Permissão	Em arquivo	Em diretório	Octal
r (leitura)	Ler o conteúdo	Listar os nomes	4
w (escrita)	Alterar o conteúdo	Criar, apagar e renomear arquivos dentro dele	2
x (execução)	Executar	Entrar (`cd`) e acessar os itens	1

```
# chown ana:financeiro orcamento.ods
# chgrp -R financeiro /srv/financeiro
# chmod 640 orcamento.ods            # rw- r-- ---
# chmod u+x,g-w,o= script.sh         # notação simbólica
# chmod -R g+rwX /srv/financeiro     # X maiúsculo: execução só em diretórios (e arquivos já
    ↪ executáveis)
```

NOTA

Quem pode **apagar** um arquivo é decidido pela permissão de escrita no **diretório**, não no arquivo. Por isso `/tmp` usa o sticky bit (seção 7).

6. umask

A **umask** define as permissões que **não** são dadas a arquivos e diretórios novos. Arquivos partem de 666 e diretórios de 777; a umask é subtraída.

umask	Arquivo novo	Diretório novo
022	644 (rw-r--r--)	755 (rwxr-xr-x)
027	640 (rw-r-----)	750 (rwxr-x---)
077	600 (rw-------)	700 (rwx------)

```
$ umask             # valor atual
$ umask 027         # vale para a sessão
```

Para tornar permanente, ajuste `UMASK` em `/etc/login.defs` (padrão do sistema) ou adicione `umask 027` em `~/.bashrc` (só um usuário).

7. Bits especiais

Bit	Em arquivo	Em diretório	Octal / símbolo
SUID	Executa com o UID do **dono** do arquivo (ex.: `/usr/bin/passwd`)	—	4000 / `s` no dono
SGID	Executa com o GID do grupo do arquivo	Arquivos criados herdam o **grupo do diretório** (ótimo para pastas de equipe)	2000 / `s` no grupo
Sticky	—	Só o dono do arquivo (ou root) pode apagá-lo (ex.: `/tmp`)	1000 / `t` nos outros

```
# chmod 2770 /srv/financeiro          # SGID: tudo que for criado fica com o grupo financeiro
# chmod 1777 /srv/compartilhado       # sticky: cada um só apaga o que é seu
$ ls -ld /tmp                          # drwxrwxrwt
# find / -perm -4000 -type f 2>/dev/null   # auditar binários SUID
```

SEGURANÇA

Binários com SUID de root são alvo clássico de elevação de privilégio. Um SUID inesperado (por exemplo numa cópia de `bash` em `/tmp`) é sinal forte de comprometimento. Mantenha uma lista de referência dos SUID legítimos e compare periodicamente.

8. ACLs

As ACLs (listas de controle de acesso POSIX) permitem dar permissões a usuários e grupos **além** do dono e do grupo do arquivo. XFS e ext4 suportam ACLs por padrão.

```
# setfacl -m u:joao:rx /srv/financeiro          # joao pode ler e entrar
# setfacl -m g:auditoria:r /srv/financeiro/orcamento.ods
# setfacl -d -m g:financeiro:rwx /srv/financeiro # ACL padrão: herdada por arquivos novos
$ getfacl /srv/financeiro
# setfacl -x u:joao /srv/financeiro             # remove uma entrada
# setfacl -b arquivo                            # remove todas
```

A **máscara** (`mask`) da ACL limita as permissões efetivas de todos os usuários e grupos nomeados; o `getfacl` mostra o "#effective" quando a máscara reduz algo.

8.1 Atributos estendidos

```
# chattr +i /etc/resolv.conf    # imutável: nem root altera ou apaga até remover o atributo
$ lsattr /etc/resolv.conf
# chattr +a /var/log/app.log    # só aceita acréscimo (append-only)
```

9. PAM em poucas palavras

O **PAM** (Pluggable Authentication Modules) é a camada que decide como cada serviço autentica, valida a conta, abre a sessão e troca senhas. Os arquivos ficam em `/etc/pam.d/`.

- **RHEL 10**: os perfis de autenticação são gerenciados pelo **authselect**, que passou a ser obrigatório. O perfil padrão em instalações novas é `local`; ao integrar com AD ou IdM, usa-se `sssd`. Não edite `/etc/pam.d/system-auth` à mão.
- **Ubuntu**: os módulos comuns são gerenciados pelo `pam-auth-update`.

```
# authselect current                              # [RHEL]
# authselect list-features local                  # [RHEL] recursos do perfil
# authselect enable-feature with-faillock         # [RHEL] ativa bloqueio após falhas
# pam-auth-update                                 # [Ubuntu] interface para habilitar módulos
# faillock --user ana                             # tentativas falhas registradas
# faillock --user ana --reset
```

LABORATÓRIO

Laboratório 3.1: equipe de projeto

- Crie os grupos `financeiro` e `auditoria` e os usuários ana, joao e maria (maria é auditora).
- Crie `/srv/financeiro` com dono root, grupo financeiro, permissões 2770.
- Dê à auditoria acesso somente leitura via ACL, incluindo arquivos futuros (ACL padrão).
- Teste com `su - ana`, `su - joao` e `su - maria` criando, lendo e apagando arquivos. Explique cada resultado.

LABORATÓRIO

Laboratório 3.2: privilégio mínimo

- Crie o grupo `operadores` e uma regra de sudo que permita apenas reiniciar e ver o status do `chronyd` (RHEL) ou `chrony` (Ubuntu).
- Tente escapar da regra (por exemplo `sudo systemctl edit`) e confirme que não consegue.
- Defina política de senha: máximo 90 dias para contas novas, troca obrigatória no primeiro login e bloqueio após 5 falhas.

Checklist de revisão

- O que fica em `/etc/passwd`, `/etc/shadow` e `/etc/group`?
- Por que `usermod -G` sem `-a` é perigoso?
- Qual o grupo administrativo no RHEL e no Ubuntu? Por que editar sudoers com `visudo`?
- Diferencie r, w e x em arquivo e em diretório. Quem pode apagar um arquivo?
- Com umask 027, quais são as permissões de um arquivo e de um diretório novos?
- Para que servem SUID, SGID em diretório e sticky bit?
- Como dar leitura a um grupo extra numa pasta, inclusive para arquivos futuros?
- Que ferramenta gerencia o PAM no RHEL 10? E no Ubuntu?

Referências oficiais

- RHEL 10: configurar autenticação e autorização (authselect, SSSD)
  https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/10/html/configuring_authentication_and_authorization_in_rhel
- RHEL 10: guia de hardening de segurança
  https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/10/html/security_hardening
- Considerações ao adotar o RHEL 10 (authselect obrigatório, perfil local)
  https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/10/html/considerations_in_adopting_rhel_10
- Documentação do Ubuntu Server
  https://ubuntu.com/server/docs/
- Ubuntu 26.04 LTS: sudo-rs e outras mudanças
  https://documentation.ubuntu.com/release-notes/26.04/summary-for-lts-users/
- Objetivos do exame RHCSA
  https://www.redhat.com/en/services/training/ex200-red-hat-certified-system-administrator-rhcsa-exam